



UNIVERSIDAD MARIANO GÁLVEZ DE GUATEMALA

FACULTAD DE INGENIERÍA EN SISTEMAS DE INFORMACIÓN

PROGRAMA DE POSGRADOS

PROYECTO FINAL

Autor (es):

Quezada Gallardo, Angelo Diancarlo – aquezadag1@miumg.edu.gt

Sosa Arroyo, Danny Josué – dsosaa1@miumg.edu.gt

Girón Rodriguez, Katherine Mishell - kgironr5@miumg.edu.gt

Arango Garcia, Josue David - jgarciaa53@miumg.edu.gt

Salazar Nájera, Javier Eduardo - jsalazarn@miumg.edu.gt

Profesor

CESAR GIOVANNI RODRIGUEZ MINAS

Curso

SEGURIDAD DE SISTEMAS INFORMÁTICO

Guatemala, 2026

INDICE

1. INTRODUCCIÓN	1
2. MARCO TEÓRICO.....	2
2.1 Seguridad de la información y la tríada CID	2
2.2 Gestión de riesgos de seguridad de la información	2
2.3 Metodología MAGERIT	3
2.4 Metodología OCTAVE Allegro.....	3
2.5 Modelo de defensa en profundidad.....	3
2.6 OWASP Top 10 y seguridad de aplicaciones	4
2.7 Síntesis del marco teórico	4
3. METODOLOGÍA	5
3.1 Alcance y activos evaluados	5
3.2 Identificación de activos, amenazas y vulnerabilidades	5
3.3 Evaluación del riesgo con MAGERIT	5
3.4 Evaluación del riesgo con OCTAVE Allegro.....	5
3.5 Clasificación y tratamiento del riesgo.....	6
4. ANÁLISIS DE RIESGOS	7
4.1 Activos del Ambiente de Producción	8
Servidor de Base de Datos (Hardware).....	8
Sistema ERP / Facturación (Software)	9
Datos de clientes (Datos)	10
Administrador de sistemas (Recursos Humanos)	11
Firewall / Router de borde (Hardware).....	12
4.2 Activos del Ambiente de Pruebas	13
Servidor de pruebas (Hardware)	13

Ambiente de staging web (Software).....	14
Datos de prueba anonimizados (Datos)	15
QA Tester (Recursos Humanos)	16
Herramienta de automatización de pruebas (Software)	17
4.3 Activos del Ambiente de Desarrollo.....	18
Estación de trabajo del desarrollador (Hardware)	18
Repositorio de código (Git) (Software)	19
Código fuente y credenciales (Datos)	20
Desarrollador (Recursos Humanos).....	21
Entorno IDE / CI-CD (Software).....	22
5. CONSOLIDACIÓN Y TRATAMIENTO DE RIESGOS.....	23
5.1 Matriz de calor	23
5.2 Consolidación por nivel de criticidad	24
5.3 Riesgos por activo evaluado	25
5.4 Priorización de acciones (Top 15)	26
6. PLAN DE IMPLEMENTACIÓN.....	28
6.1 Fase 1: Acción inmediata (0-3 meses)	28
6.2 Fase 2: Corto plazo (3-6 meses).....	29
6.3 Fase 3: Mediano plazo (6-12 meses)	30
6.4 Cronograma general.....	30
6.5 Presupuesto estimado y reducción del impacto financiero	30
7. ANÁLISIS DE BRECHAS.....	32
8. ASPECTOS NORMATIVOS Y LEGALES	33
8.1 Marco normativo nacional (Guatemala)	33
8.2 Marcos y estándares internacionales de referencia	33

8.3 Implicaciones para el tratamiento de riesgos	34
9. PLAN DE CONTINUIDAD DE NEGOCIO	35
9.1 Objetivo y alcance.....	35
9.2 Análisis de impacto al negocio (BIA) y objetivos de recuperación.....	35
9.3 Estrategias de continuidad	36
9.4 Roles, responsabilidades y comunicación.....	36
9.5 Pruebas y mantenimiento del plan	36
10. CONCLUSIONES	37
11. REFERENCIAS.....	38
12. ANEXOS	39

ÍNDICE DE TABLAS

<i>Tabla 1. Riesgos identificados — Servidor de Base de Datos (Hardware)</i>	8
<i>Tabla 2. Riesgos identificados — Sistema ERP / Facturación (Software)</i>	9
<i>Tabla 3. Riesgos identificados — Datos de clientes (Datos)</i>	10
<i>Tabla 4. Riesgos identificados — Administrador de sistemas (Recursos Humanos)</i>	11
<i>Tabla 5. Riesgos identificados — Firewall / Router de borde (Hardware)</i>	12
<i>Tabla 6. Riesgos identificados — Servidor de pruebas (Hardware)</i>	13
<i>Tabla 7. Riesgos identificados — Ambiente de staging web (Software)</i>	14
<i>Tabla 8. Riesgos identificados — Datos de prueba anonimizados (Datos)</i>	15
<i>Tabla 9. Riesgos identificados — QA Tester (Recursos Humanos)</i>	16
<i>Tabla 10. Riesgos identificados — Herramienta de automatización de pruebas (Software)</i>	17
<i>Tabla 11. Riesgos identificados — Estación de trabajo del desarrollador (Hardware)</i>	18
<i>Tabla 12. Riesgos identificados — Repositorio de código (Git) (Software)</i>	19
<i>Tabla 13. Riesgos identificados — Código fuente y credenciales (Datos)</i>	20
<i>Tabla 14. Riesgos identificados — Desarrollador (Recursos Humanos)</i>	21
<i>Tabla 15. Riesgos identificados — Entorno IDE / CI-CD (Software)</i>	22

ÍNDICE DE FIGURAS

<i>Figura 1. Riesgos por ambiente evaluado, según nivel de criticidad MAGERIT.....</i>	<i>7</i>
<i>Figura 2. Riesgos por nivel de criticidad, según activo evaluado.....</i>	<i>8</i>
<i>Figura 3. Matriz de calor: frecuencia de riesgos por probabilidad x impacto.</i>	<i>23</i>
<i>Figura 4. Distribución de los 150 riesgos por nivel de criticidad (MAGERIT vs. OCTAVE Allegro).</i>	<i>24</i>
<i>Figura 5. Distribución general de los 150 riesgos por nivel MAGERIT.....</i>	<i>25</i>
<i>Figura 6. Riesgos por nivel de criticidad, según activo evaluado.....</i>	<i>26</i>
<i>Figura 7. Top 15 riesgos de mayor puntaje MAGERIT.....</i>	<i>27</i>
<i>Figura 8. Cronograma general de implementación.</i>	<i>30</i>
<i>Figura 9. Presupuesto estimado por fase de implementación.</i>	<i>31</i>
<i>Figura 10. Brechas recurrentes por capa de seguridad (defensa en profundidad).</i>	<i>32</i>
<i>Figura 11. Objetivos de recuperación (RTO/RPO) por activo crítico.</i>	<i>35</i>

1. INTRODUCCIÓN

En la actualidad, la seguridad de la información constituye un elemento fundamental para garantizar la continuidad, confiabilidad y protección de los sistemas que soportan las operaciones de una organización. La creciente dependencia de plataformas tecnológicas, bases de datos, aplicaciones y ambientes de desarrollo incrementa la exposición ante amenazas que pueden comprometer la confidencialidad, integridad y disponibilidad de la información. En este contexto, la gestión de riesgos permite identificar de manera estructurada las amenazas y vulnerabilidades que pueden afectar los activos, valorar su probabilidad e impacto y establecer medidas de tratamiento acordes con su nivel de criticidad.

El presente trabajo desarrolla un análisis de riesgos de seguridad de la información aplicado a 15 activos tecnológicos y humanos de una organización, distribuidos en los ambientes de Producción, Pruebas y Desarrollo. Para cada activo se evaluaron de forma uniforme las diez capas del modelo de defensa en profundidad (física, red, host, aplicación, datos, gestión de identidad y acceso, monitoreo y respuesta, continuidad y respaldo, seguridad perimetral y concientización/procesos), dando como resultado un total de 150 riesgos analizados bajo las metodologías MAGERIT y OCTAVE Allegro, complementadas con los principios del OWASP Top 10.

A partir de este análisis se examinan riesgos asociados con explotación de vulnerabilidades conocidas, exposición de credenciales, ataques de fuerza bruta, fraude interno, accesos no autorizados y debilidades de configuración, entre otros. El resultado global no registró riesgos de nivel crítico bajo la escala MAGERIT; sin embargo, 76 de los 150 riesgos (poco más de la mitad) se clasificaron como de nivel alto, lo que evidencia una superficie de exposición considerable que exige un plan de tratamiento priorizado y una gestión presupuestaria escalonada para reducir el impacto financiero potencial de su materialización.

2. MARCO TEÓRICO

El presente trabajo se fundamenta en un conjunto de conceptos, metodologías y estándares propios de la seguridad de la información, orientados a identificar, valorar y tratar los riesgos que afectan a los activos de una organización. A continuación, se desarrollan los términos clave que sustentan el análisis realizado.

2.1 Seguridad de la información y la tríada CID

La seguridad de la información es el conjunto de principios, políticas y controles orientados a proteger los activos de información frente a amenazas que puedan comprometer su valor para la organización. Su fundamento conceptual es la tríada CID, integrada por la confidencialidad, que garantiza que la información solo sea accesible para quienes están autorizados a conocerla; la integridad, que asegura que los datos no sean alterados de forma no autorizada o accidental; y la disponibilidad, que garantiza el acceso oportuno a la información y a los sistemas cuando estos son requeridos. A estas dimensiones básicas, marcos como MAGERIT añaden la autenticidad, que certifica el origen legítimo de la información o de quien la genera, y la trazabilidad, que permite reconstruir quién realizó una acción determinada y en qué momento (Ministerio de Hacienda y Administraciones Públicas, 2012a).

2.2 Gestión de riesgos de seguridad de la información

La gestión de riesgos es el proceso sistemático mediante el cual una organización identifica sus activos de información, reconoce las amenazas que podrían afectarlos y las vulnerabilidades que estas amenazas podrían explotar, para luego estimar la probabilidad de ocurrencia y el impacto potencial de cada escenario. Con base en esa estimación se determina el nivel de riesgo y se define su tratamiento, que puede consistir en mitigarlo mediante controles, transferirlo a un tercero, evitarlo o aceptarlo formalmente. La norma ISO/IEC 27005 (2018) establece las directrices internacionales para este proceso, proporcionando un marco de referencia común que numerosas metodologías nacionales, como MAGERIT, adoptan y adaptan a su propio contexto.

2.3 Metodología MAGERIT

MAGERIT (Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información) es una metodología desarrollada por el Gobierno de España que ofrece un método estructurado para analizar los riesgos que afectan a los sistemas de información y para planificar el tratamiento oportuno de dichos riesgos. Su enfoque valora cada activo según las dimensiones de seguridad que podrían verse comprometidas —confidencialidad, integridad, disponibilidad, autenticidad y trazabilidad— y calcula el riesgo resultante a partir de la combinación entre la probabilidad de que la amenaza se materialice y el impacto que esta generaría sobre el activo. Este cálculo permite clasificar los riesgos en niveles como bajo, moderado, alto o crítico, facilitando la priorización de las medidas de mitigación (Ministerio de Hacienda y Administraciones Públicas, 2012a, 2012b).

2.4 Metodología OCTAVE Allegro

OCTAVE Allegro es un enfoque de evaluación de riesgos desarrollado por el Software Engineering Institute de la Universidad Carnegie Mellon, orientado principalmente a los activos de información considerados esenciales para la organización. A diferencia de metodologías centradas en la infraestructura tecnológica, OCTAVE Allegro parte del activo de información y analiza los contenedores donde este reside —ya sean sistemas, personas o instalaciones físicas—, el actor que representa la amenaza y el requisito de seguridad que resultaría afectado en caso de materializarse el riesgo. Este enfoque complementa a MAGERIT al aportar una perspectiva centrada en el valor del activo para el negocio y en la prioridad de protección que este merece (Caralli et al., 2007).

2.5 Modelo de defensa en profundidad

La defensa en profundidad es un principio de diseño de seguridad que propone la implementación de múltiples capas de control complementarias, de manera que si un atacante logra vulnerar una de ellas, las capas restantes continúen protegiendo el activo. En este trabajo se aplicaron de forma sistemática diez capas a cada uno de los 15 activos evaluados: seguridad física, seguridad de red, seguridad de host, seguridad de aplicación, seguridad de datos, gestión de identidad y acceso, monitoreo y respuesta, continuidad y respaldo, seguridad perimetral, y concientización y procesos. Este modelo permitió estructurar de forma ordenada y uniforme el análisis de riesgos y las soluciones de mitigación propuestas.

2.6 OWASP Top 10 y seguridad de aplicaciones

El proyecto OWASP (Open Web Application Security Project) publica de forma periódica el documento OWASP Top 10, un catálogo de referencia internacional que resume los riesgos más críticos y frecuentes en aplicaciones web, entre ellos la inyección de código, el control de acceso deficiente y la exposición de datos sensibles. Este catálogo constituye una guía práctica ampliamente adoptada por la industria para orientar las prácticas de codificación segura, la validación de entradas y las revisiones de seguridad durante el ciclo de vida del desarrollo de software (OWASP Foundation, 2021).

2.7 Síntesis del marco teórico

En conjunto, estos conceptos y metodologías conforman la base conceptual sobre la cual se desarrolla el análisis de riesgos del presente trabajo: la tríada CID y sus dimensiones extendidas permiten definir qué se protege; ISO/IEC 27005 aporta el proceso general de gestión de riesgos; MAGERIT y OCTAVE Allegro ofrecen métodos complementarios para valorar y priorizar dichos riesgos; el modelo de defensa en profundidad organiza las soluciones de mitigación por capas de forma sistemática sobre cada activo; y el OWASP Top 10 orienta las medidas específicas de seguridad en el ámbito del desarrollo de aplicaciones.

3. METODOLOGÍA

El presente trabajo se desarrolló bajo un enfoque cualitativo-cuantitativo de tipo descriptivo, aplicando de forma estructurada las metodologías MAGERIT y OCTAVE Allegro para la identificación, valoración y tratamiento de los riesgos de seguridad de la información. El procedimiento se ejecutó en las fases que se describen a continuación.

3.1 Alcance y activos evaluados

El análisis se realizó sobre los tres ambientes en los que opera la organización — producción, pruebas y desarrollo— cubriendo 15 activos distribuidos en cuatro categorías: hardware (servidor de base de datos, firewall/router de borde, servidor de pruebas, estación de trabajo del desarrollador), software (sistema ERP/facturación, ambiente de staging web, herramienta de automatización de pruebas, repositorio de código Git, entorno IDE/CI-CD), datos (datos de clientes, datos de prueba anonimizados, código fuente y credenciales) y recursos humanos (administrador de sistemas, QA Tester, desarrollador). Cada activo fue evaluado bajo las diez capas del modelo de defensa en profundidad, generando un total de 150 riesgos.

3.2 Identificación de activos, amenazas y vulnerabilidades

Para cada activo se identificó, en cada una de las diez capas de seguridad, la brecha o debilidad presente y la amenaza correspondiente, entendida como el actor y el evento que podría explotar dicha brecha. Este ejercicio se documentó de forma individual para cada uno de los 150 riesgos, indicando además la capa de seguridad por profundidad comprometida.

3.3 Evaluación del riesgo con MAGERIT

Cada riesgo identificado fue evaluado aplicando la escala de valoración de MAGERIT, estimando la probabilidad de ocurrencia y el impacto sobre una escala de 1 a 5. A partir de la combinación de probabilidad e impacto se determinó el nivel de riesgo resultante, clasificado en las categorías bajo, moderado, alto o crítico (Ministerio de Hacienda y Administraciones Públicas, 2012b).

3.4 Evaluación del riesgo con OCTAVE Allegro

De forma complementaria, cada riesgo se evaluó bajo el enfoque OCTAVE Allegro, considerando la criticidad del activo contenedor (definida en el inventario de activos a partir de

su valor, impacto en el negocio y confidencialidad) para ponderar el riesgo resultante y su nivel correspondiente (Caralli et al., 2007).

3.5 Clasificación y tratamiento del riesgo

Con base en los resultados obtenidos de ambas metodologías, los 150 riesgos se ubicaron en una matriz de calor que permitió visualizar de manera conjunta su probabilidad e impacto, facilitando la priorización de los riesgos de mayor puntaje. Para cada riesgo se definió un tratamiento (mitigar/reducir, transferir, evitar o aceptar) y se propuso una solución específica de mitigación, alineada con buenas prácticas de la industria.

4. ANÁLISIS DE RIESGOS

Esta sección presenta el análisis de riesgos de seguridad de la información sobre los 15 activos evaluados en los tres ambientes de la organización, aplicando de forma uniforme las diez capas del modelo de defensa en profundidad a cada uno. En total se identificaron y evaluaron 150 riesgos bajo las metodologías MAGERIT y OCTAVE Allegro. Los riesgos se presentan de forma narrativa por activo; el detalle numérico agregado se ilustra en las gráficas siguientes.

Figura 1. Riesgos por ambiente evaluado, según nivel de criticidad MAGERIT.

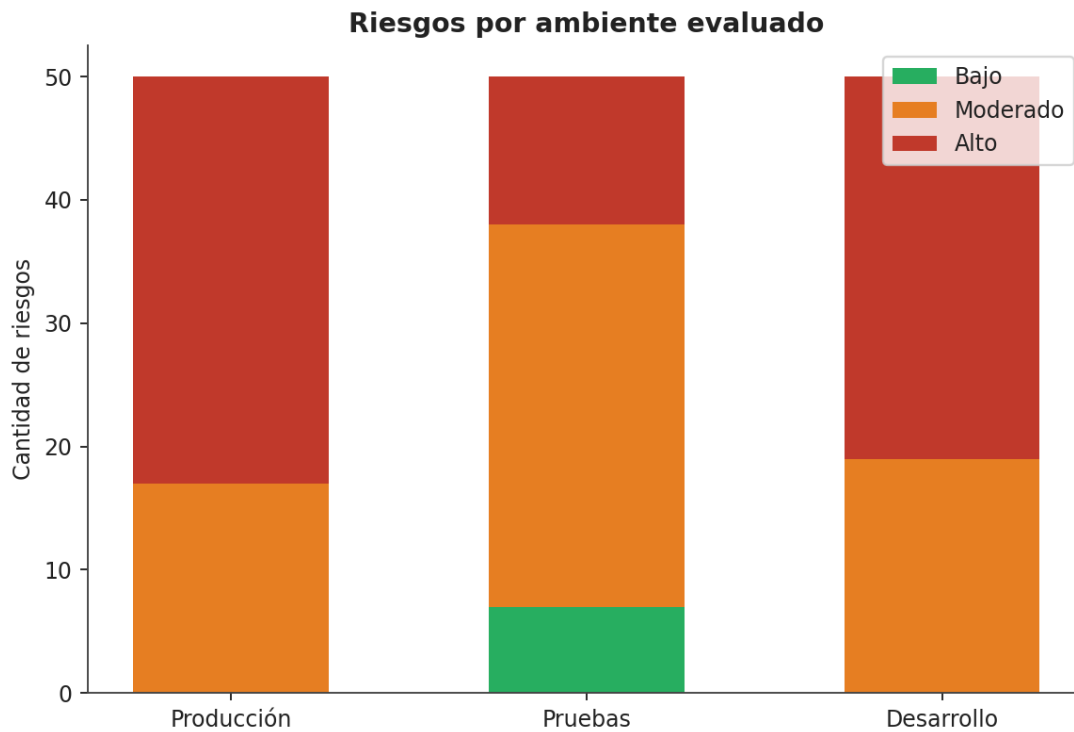
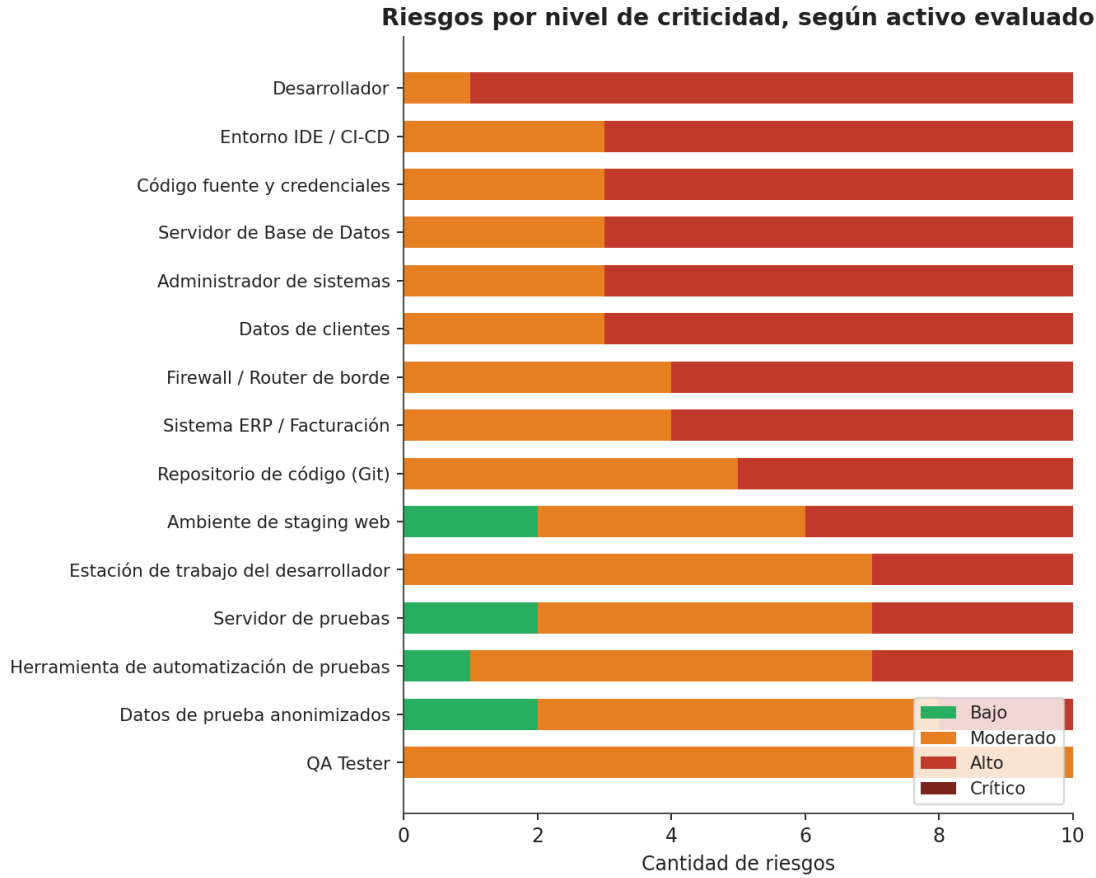


Figura 2. Riesgos por nivel de criticidad, según activo evaluado.



4.1 Activos del Ambiente de Producción

Servidor de Base de Datos (Hardware)

Responsable: Danny. Criticidad del activo: 5 (Alta). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 1. Riesgos identificados — *Servidor de Base de Datos (Hardware)*

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamiento	Solución
1	Seguridad Física	Acceso no autorizado al cuarto de servidores / Robo o sabotaje de hardware	2	5	10 (Moderado)	10 (Moderado)	Reducir/Mitigar	Control de acceso biométrico y CCTV en el cuarto de servidores, con bitácora de ingreso.
2	Seguridad de Red	Puertos de administración expuestos a la red interna / Acceso remoto no autorizado	3	5	15 (Alto)	15 (Alto)	Reducir/Mitigar	Segmentar la red de administración (VLAN dedicada) y exigir VPN + MFA para acceso remoto.
3	Seguridad de Host	Sistema operativo del servidor desactualizado / Explotación de vulnerabilidades conocidas	4	4	16 (Alto)	16 (Alto)	Reducir/Mitigar	Gestión de parches automatizada y hardening del sistema operativo del servidor.

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
4	Seguridad de Aplicación	Motor de base de datos con configuración por defecto / Inyección SQL / escalamiento de privilegios	3	5	15 (Alto)	15 (Alto)	Reducir/Mitigar	Validación de entradas, consultas parametrizadas y bastionado del motor de base de datos.
5	Seguridad de Datos	Ausencia de cifrado en datos en reposo / Fuga de información confidencial	3	5	15 (Alto)	15 (Alto)	Reducir/Mitigar	Cifrar los datos en reposo (TDE) y en tránsito (TLS).
6	Gestión de Identidad y Acceso	Cuentas de administrador compartidas / Uso indebido de credenciales privilegiadas	3	4	12 (Alto)	12 (Alto)	Reducir/Mitigar	Cuentas nominales, mínimo privilegio y bóveda de contraseñas (PAM).
7	Monitoreo y Respuesta	Falta de registro (logging) centralizado / Detección tardía de incidentes	3	3	9 (Moderado)	9 (Moderado)	Reducir/Mitigar	Centralizar logs en un SIEM con alertas en tiempo real.
8	Continuidad y Respaldo	Respaldos no probados periódicamente / Pérdida de datos ante fallo o ataque	2	5	10 (Moderado)	10 (Moderado)	Reducir/Mitigar	Plan de respaldo 3-2-1 con pruebas periódicas de restauración.
9	Seguridad Perimetral	Reglas de firewall obsoletas o permisivas / Movimiento lateral de un atacante	3	4	12 (Alto)	12 (Alto)	Reducir/Mitigar	Revisar y depurar reglas de firewall; segmentación/microsegmentación de red.
10	Concientización y Procesos	Falta de procedimiento de gestión de parches / Explotación de vulnerabilidades no corregidas	4	4	16 (Alto)	16 (Alto)	Reducir/Mitigar	Proceso formal de gestión de parches con SLA de aplicación.

Sistema ERP / Facturación (Software)

Responsable: Javier. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 2. Riesgos identificados — Sistema ERP / Facturación (Software)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
11	Seguridad Física	Servidores del ERP alojados sin control de acceso físico restringido / Acceso físico no autorizado al hardware que aloja el ERP	2	4	8 (Moderado)	5 (Bajo)	Reducir/Mitigar	Alojar el servidor en centro de datos con control de acceso y video vigilancia.
12	Seguridad de Red	Comunicación del ERP sin cifrado entre módulos / Intercepción de tráfico (sniffing)	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Cifrar comunicaciones internas con TLS y segmentar la red del ERP.
13	Seguridad de Host	Servidor de aplicaciones del ERP sin actualizaciones de seguridad / Explotación de vulnerabilidades del sistema operativo	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Ciclo de actualización mensual y bastionado del servidor.
14	Seguridad de Aplicación	Módulo de facturación sin validación de entradas / Inyección de código / manipulación de transacciones	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Pruebas de seguridad de aplicaciones (SAST/DAST) antes de cada release.
15	Seguridad de Datos	Base de datos del ERP sin cifrado de campos sensibles (montos, NIT) / Exposición de información financiera	2	5	10 (Moderado)	6 (Moderado)	Reducir/Mitigar	Cifrar campos sensibles y enmascarar datos en reportes.
16	Gestión de Identidad y Acceso	Roles del ERP mal configurados (usuarios con permisos excesivos) / Fraude	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Revisión periódica de roles y segregación de funciones (SoD).

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
17	Monitoreo y Respuesta	interno o modificación indebida de facturas Ausencia de alertas ante transacciones inusuales / Fraude no detectado a tiempo	3	4	12 (Alto)	7 (Moderado)	Reducir/Mit igar	Reglas de auditoría y alertas de transacciones atípicas.
18	Continuidad y Respaldo	Backup del ERP solo en sitio, sin copia externa / Pérdida de información contable ante desastre	2	5	10 (Moderado)	6 (Moderado)	Reducir/Mit igar	Respaldo en la nube con retención definida y prueba de restauración.
19	Seguridad Perimetral	Puerto de administración del ERP expuesto a internet / Acceso externo no autorizado a la consola de administración	3	4	12 (Alto)	7 (Moderado)	Reducir/Mit igar	Restringir el acceso administrativo a IPs internas mediante firewall/VPN.
20	Concientización y Procesos	Falta de capacitación a usuarios sobre manejo del ERP / Errores de captura y fraude por desconocimiento	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mit igar	Capacitación periódica y manual de procedimientos de uso.

Datos de clientes (Datos)

Responsable: Katherin. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 3. Riesgos identificados — Datos de clientes (Datos)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
21	Seguridad Física	Medios de respaldo con datos de clientes almacenados sin resguardo físico / Robo o pérdida de medios de respaldo	2	5	10 (Moderado)	6 (Moderado)	Reducir/Mit igar	Resguardo en caja fuerte o custodia externa certificada.
22	Seguridad de Red	Transferencia de datos de clientes entre sistemas sin cifrado / Intercepción de información personal en tránsito	3	5	15 (Alto)	9 (Moderado)	Reducir/Mit igar	Cifrado TLS obligatorio en todas las transferencias de datos.
23	Seguridad de Host	Base de datos de clientes en servidor sin bastionado específico / Compromiso del servidor que aloja los datos	3	5	15 (Alto)	9 (Moderado)	Reducir/Mit igar	Hardening del servidor de base de datos y monitoreo de integridad.
24	Seguridad de Aplicación	Aplicaciones con acceso directo a la base de datos sin capa de control / Exfiltración de datos mediante consultas no controladas	3	5	15 (Alto)	9 (Moderado)	Reducir/Mit igar	Implementar capa de API con control de acceso y limitación de consultas.
25	Seguridad de Datos	Datos personales sin cifrado ni enmascaramiento / Fuga de información personal (incumplimiento normativo)	3	5	15 (Alto)	9 (Moderado)	Reducir/Mit igar	Cifrado de campos sensibles y clasificación de datos personales.
26	Gestión de Identidad y Acceso	Múltiples roles con acceso de lectura/escritura a todos los datos de clientes / Acceso indebido o excesivo a información personal	3	5	15 (Alto)	9 (Moderado)	Reducir/Mit igar	Control de acceso basado en roles con mínimo privilegio.
27	Monitoreo y Respuesta	Sin auditoría de consultas a datos sensibles de clientes / Acceso indebido no detectado	3	4	12 (Alto)	7 (Moderado)	Reducir/Mit igar	Auditoría de accesos a datos sensibles (Database Activity Monitoring).
28	Continuidad y Respaldo	Respaldos de datos de clientes sin cifrado / Exposición de datos personales ante robo de respaldo	2	5	10 (Moderado)	6 (Moderado)	Reducir/Mit igar	Cifrado de respaldos y control de acceso a los mismos.

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
29	Seguridad Perimetral	Exportaciones masivas de datos permitidas sin control / Exfiltración masiva de datos de clientes	2	5	10 (Moderado)	6 (Moderado)	Reducir/Mitigar	Limitar y auditar las exportaciones masivas de datos (DLP).
30	Concientización y Procesos	Falta de política de protección de datos personales / Manejo inadecuado de datos por parte del personal	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Política de protección de datos y capacitación en normativa aplicable.

Administrador de sistemas (Recursos Humanos)

Responsable: Josue. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 4. Riesgos identificados — Administrador de sistemas (Recursos Humanos)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
31	Seguridad Física	Sin control de acceso a áreas críticas para el administrador de sistemas / Ingreso no autorizado a zonas restringidas	2	3	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Control de acceso físico basado en roles y bitácora de ingreso.
32	Seguridad de Red	Acceso remoto del administrador sin restricciones ni VPN / Interceptación de sesiones de administración remota	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Acceso remoto únicamente mediante VPN con MFA.
33	Seguridad de Host	Estación del administrador sin controles reforzados pese a sus privilegios / Compromiso del equipo usado para tareas administrativas	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Estación dedicada y reforzada (PAW) para tareas administrativas.
34	Seguridad de Aplicación	Uso de una sola cuenta de administrador para múltiples sistemas / Movimiento lateral en caso de compromiso de la cuenta	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Cuentas administrativas separadas por sistema y uso de PAM.
35	Seguridad de Datos	Acceso amplio del administrador a todos los datos sin justificación operativa / Abuso de privilegios para acceder a información sensible	2	4	8 (Moderado)	5 (Bajo)	Reducir/Mitigar	Limitar el acceso a datos según necesidad y registrar accesos privilegiados.
36	Gestión de Identidad y Acceso	Falta de revisión periódica de privilegios asignados al rol / Acumulación de privilegios innecesarios (privilege creep)	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Revisión periódica de privilegios y certificación de accesos.
37	Monitoreo y Respuesta	Actividades del administrador no auditadas de forma independiente / Acciones maliciosas o erróneas sin detección (amenaza interna)	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Auditoría independiente y grabación de sesiones privilegiadas.
38	Continuidad y Respaldo	Dependencia de una sola persona para tareas administrativas críticas / Interrupción de operaciones ante ausencia del administrador	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Documentar procedimientos y contar con un administrador de respaldo.
39	Seguridad Perimetral	Acceso administrativo posible desde cualquier ubicación sin restricción geográfica /	2	4	8 (Moderado)	5 (Bajo)	Reducir/Mitigar	Restringir accesos administrativos por

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
40	Concientización y Procesos	Acceso indebido desde ubicaciones no habituales Falta de capacitación continua en nuevas amenazas de ciberseguridad / Desactualización frente a nuevas técnicas de ataque (ingeniería social)	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	geolocalización/IP y alertar anomalías. Capacitación continua y simulacros de phishing dirigidos.

Firewall / Router de borde (Hardware)

Responsable: Diancarlo. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 5. Riesgos identificados — Firewall / Router de borde (Hardware)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
41	Seguridad Física	Firewall/router ubicado en gabinete sin cerradura / Manipulación física del dispositivo perimetral	2	4	8 (Moderado)	5 (Bajo)	Reducir/Mitigar	Reubicar el equipo en rack con cerradura y control de acceso.
42	Seguridad de Red	Interfaz de administración accesible desde la red interna sin restricción / Reconfiguración no autorizada de reglas	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Aislar la interfaz de gestión en una VLAN de administración dedicada.
43	Seguridad de Host	Firmware del firewall desactualizado / Explotación de vulnerabilidades conocidas del firmware	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Plan de actualización de firmware y suscripción a boletines del fabricante.
44	Seguridad de Aplicación	Panel de administración web sin límite de intentos de login / Ataque de fuerza bruta a la consola	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Bloqueo por intentos fallidos y autenticación multifactor.
45	Seguridad de Datos	Configuración del firewall sin respaldo cifrado / Exposición de reglas de seguridad ante robo de respaldo	2	3	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Cifrar y resguardar los respaldos de configuración.
46	Gestión de Identidad y Acceso	Cuenta única de administrador para todo el equipo de redes / Falta de trazabilidad en cambios de configuración	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Cuentas individuales con roles y registro de auditoría (AAA/RADIUS).
47	Monitoreo y Respuesta	No se revisan los logs del firewall regularmente / Intentos de intrusión no detectados	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Envío de logs a SIEM con alertas de eventos críticos.
48	Continuidad y Respaldo	No existe equipo de respaldo (failover) para el firewall / Interrupción total de conectividad ante falla	2	5	10 (Moderado)	6 (Moderado)	Reducir/Mitigar	Implementar configuración de alta disponibilidad (HA) activo-pasivo.
49	Seguridad Perimetral	Reglas de firewall permisivas (ANY-ANY) heredadas / Tráfico malicioso permitido hacia la red interna	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Auditoría y depuración de reglas siguiendo el principio de mínimo privilegio.
50	Concientización y Procesos	Falta de procedimiento documentado de cambios / Cambios no controlados que generan brechas	2	3	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Implementar proceso formal de gestión de cambios (change management).

4.2 Activos del Ambiente de Pruebas

Servidor de pruebas (Hardware)

Responsable: Danny. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 6. Riesgos identificados — Servidor de pruebas (Hardware)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamiento	Solución
51	Seguridad Física	Servidor de pruebas ubicado en área de oficina sin control de acceso / Acceso físico no autorizado	2	2	4 (Bajo)	2 (Bajo)	Aceptar	Aceptar el riesgo por bajo impacto, documentando la decisión, o reubicar a rack cerrado.
52	Seguridad de Red	Servidor de pruebas conectado a la misma red que producción / Pivote hacia sistemas productivos	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Segmentar la red de pruebas en una VLAN aislada de producción.
53	Seguridad de Host	Sistema operativo de pruebas sin parches por priorizarse funcionalidad / Explotación de vulnerabilidades sin corregir	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Incluir el servidor de pruebas en el ciclo de gestión de parches.
54	Seguridad de Aplicación	Aplicaciones en prueba con configuraciones de depuración activas / Exposición de información sensible por mensajes de error	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Deshabilitar el modo debug antes de exponer el ambiente.
55	Seguridad de Datos	Uso de datos reales de producción sin anonimizar / Fuga de información confidencial desde el ambiente de pruebas	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Anonimizar/enmascarar datos antes de cargarlos en pruebas.
56	Gestión de Identidad y Acceso	Credenciales por defecto sin cambiar en el ambiente de pruebas / Acceso no autorizado al servidor	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Forzar cambio de credenciales por defecto y política de contraseñas.
57	Monitoreo y Respuesta	Sin monitoreo activo por considerarse ambiente no crítico / Uso indebido no detectado	3	2	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Incluir el servidor en el monitoreo básico centralizado.
58	Continuidad y Respaldo	Sin respaldo del ambiente de pruebas / Pérdida de configuraciones y avances de prueba	2	2	4 (Bajo)	2 (Bajo)	Aceptar	Aceptar el riesgo o programar respaldos de baja frecuencia.
59	Seguridad Perimetral	Acceso remoto (RDP/SSH) expuesto directamente a internet / Ataques de fuerza bruta desde internet	4	4	16 (Alto)	10 (Moderado)	Reducir/Mitigar	Cerrar el acceso directo a internet y usar VPN o bastion host.
60	Concientización y Procesos	Falta de lineamientos sobre uso de datos en ambientes de prueba / Manejo inadecuado de información sensible por el equipo de QA	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Política de manejo de datos de prueba y capacitación al equipo.

Ambiente de staging web (Software)

Responsable: Javier. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 7. Riesgos identificados — Ambiente de staging web (Software)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamiento	Solución
61	Seguridad Física	Servidor de staging alojado en el mismo rack sin separación lógica / Acceso físico no controlado	2	2	4 (Bajo)	2 (Bajo)	Aceptar	Aceptar el riesgo o segregar físicamente el equipo del resto de la infraestructura.
62	Seguridad de Red	Staging accesible desde internet sin restricción de IP / Escaneo y explotación por actores externos	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Restringir acceso a IPs autorizadas y usar autenticación básica adicional.
63	Seguridad de Host	Servidor de staging con configuración idéntica a producción pero sin parches recientes / Explotación de vulnerabilidades	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Incluir staging en el ciclo de parcheo regular.
64	Seguridad de Aplicación	Código en staging con features no probadas y mensajes de error detallados / Divulgación de información técnica (stack traces)	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Configurar manejo de errores genérico también en staging.
65	Seguridad de Datos	Uso de copia de base de datos de producción sin anonimizar / Exposición de datos reales de clientes	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Anonimización obligatoria de datos antes de cargarlos a staging.
66	Gestión de Identidad y Acceso	Usuario y contraseña compartidos entre todo el equipo de QA / Falta de trazabilidad de cambios	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Cuentas individuales con inicio de sesión único (SSO) corporativo.
67	Monitoreo y Respuesta	No se revisan logs del ambiente de staging / Actividad anómala no detectada antes de pasar a producción	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Integrar staging al monitoreo centralizado con alertas básicas.
68	Continuidad y Respaldo	Sin respaldo del ambiente de staging / Pérdida de configuración de pruebas	2	2	4 (Bajo)	2 (Bajo)	Aceptar	Aceptar el riesgo dado el bajo impacto del ambiente.
69	Seguridad Perimetral	Puertos de depuración (debug) abiertos al exterior / Explotación de endpoints de desarrollo expuestos	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Cerrar puertos de depuración antes de publicar el ambiente.
70	Concientización y Procesos	Falta de checklist de seguridad previo a promover cambios a producción / Vulnerabilidades no detectadas que pasan a producción	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Checklist de seguridad y revisión de código previo al despliegue.

Datos de prueba anonimizados (Datos)

Responsable: Katherin. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 8. Riesgos identificados — Datos de prueba anonimizados (Datos)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
71	Seguridad Física	Medios con datos de prueba sin resguardo físico / Acceso físico no autorizado a medios de almacenamiento	2	2	4 (Bajo)	2 (Bajo)	Aceptar	Aceptar el riesgo por bajo impacto, dado que los datos están anonimizados.
72	Seguridad de Red	Transferencia de datos de prueba sin cifrado entre ambientes / Intercepción de datos durante la carga a pruebas	2	3	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Cifrar la transferencia de datos entre ambientes (SFTP/TLS).
73	Seguridad de Host	Servidor de datos de prueba con controles menos estrictos que producción / Compromiso del servidor de pruebas	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Aplicar controles de seguridad equivalentes a producción, ajustados al riesgo.
74	Seguridad de Aplicación	Scripts de anonimización no validados formalmente / Anonimización incompleta que deja datos identificables	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Validar y auditar el proceso de anonimización antes de su uso.
75	Seguridad de Datos	Proceso de anonimización reversible o débil / Reidentificación de personas a partir de datos anonimizados	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Uso de técnicas robustas de anonimización/seudonimización irreversibles.
76	Gestión de Identidad y Acceso	Acceso a datos de prueba sin restricción para todo el equipo de QA/desarrollo / Uso indebido de datos por personal sin necesidad de acceso	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Restringir el acceso a datos de prueba según necesidad (need-to-know).
77	Monitoreo y Respuesta	Sin monitoreo del uso de datos de prueba / Extracción o copia no autorizada de datos de prueba	2	3	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Registrar y monitorear el acceso a los conjuntos de datos de prueba.
78	Continuidad y Respaldo	Sin respaldo formal de los conjuntos de datos de prueba / Pérdida de datasets preparados para pruebas	2	2	4 (Bajo)	2 (Bajo)	Aceptar	Aceptar el riesgo por el bajo costo de regenerar los datos de prueba.
79	Seguridad Perimetral	Datos de prueba accesibles desde ambientes no controlados (equipos personales) / Fuga de datos hacia entornos externos	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Restringir el uso de datos de prueba a entornos corporativos controlados.
80	Concientización y Procesos	Falta de lineamientos claros sobre generación y uso de datos anonimizados / Generación de datos de prueba inadecuadamente anonimizados	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Guía y capacitación sobre anonimización y manejo de datos de prueba.

QA Tester (Recursos Humanos)

Responsable: Josue. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 9. Riesgos identificados — QA Tester (Recursos Humanos)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
81	Seguridad Física	Estación del QA sin bloqueo automático de sesión / Acceso no autorizado al dejar la sesión abierta	3	2	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Configurar bloqueo automático de pantalla tras inactividad.
82	Seguridad de Red	QA accede a ambientes de prueba desde redes no corporativas sin VPN / Exposición de accesos desde redes no confiables	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Exigir VPN para el acceso a ambientes de prueba desde fuera de la oficina.
83	Seguridad de Host	Estación de QA sin antivirus actualizado / Infección de malware que comprometa credenciales de prueba	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Antivirus/EDR gestionado y actualizado automáticamente.
84	Seguridad de Aplicación	Uso de cuentas de prueba con privilegios elevados innecesarios / Uso indebido de accesos de prueba con altos privilegios	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Asignar a QA solo los privilegios necesarios para las pruebas.
85	Seguridad de Datos	QA maneja datos de prueba potencialmente sensibles sin lineamientos / Divulgación accidental de información en reportes de bugs	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Lineamientos de manejo de datos sensibles en reportes y evidencias de prueba.
86	Gestión de Identidad y Acceso	Credenciales de prueba compartidas entre varios testers / Falta de trazabilidad de acciones realizadas	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Credenciales individuales para cada tester.
87	Monitoreo y Respuesta	Actividad del rol de QA no se audita / Uso indebido de accesos de prueba sin detección	2	3	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Incluir las cuentas de QA en el monitoreo de actividad general.
88	Continuidad y Respaldo	Dependencia de un solo tester para casos de prueba críticos / Retraso en pruebas críticas ante ausencia del tester	3	2	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Documentar casos de prueba y capacitar a más de una persona.
89	Seguridad Perimetral	Acceso de QA a sistemas de producción para validar incidentes / Uso indebido de accesos de prueba en el ambiente productivo	2	4	8 (Moderado)	5 (Bajo)	Reducir/Mitigar	Prohibir el acceso de QA a producción y usar réplicas para validación.
90	Concientización y Procesos	Falta de capacitación en seguridad para el equipo de QA / Reporte inadecuado de vulnerabilidades encontradas (fuga de información)	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Capacitar al equipo de QA en manejo responsable de hallazgos de seguridad.

Herramienta de automatización de pruebas (Software)

Responsable: Diancarlo. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 10. Riesgos identificados — Herramienta de automatización de pruebas (Software)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamiento	Solución
91	Seguridad Física	Servidor de la herramienta de automatización sin acceso restringido / Acceso físico no autorizado	2	2	4 (Bajo)	2 (Bajo)	Aceptar	Aceptar el riesgo por bajo impacto, o ubicar el servidor en área restringida.
92	Seguridad de Red	Herramienta de automatización accesible desde toda la red sin segmentación / Acceso no autorizado a scripts y resultados de prueba	2	3	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Restringir acceso mediante VLAN y control de firewall.
93	Seguridad de Host	Servidor con dependencias y librerías desactualizadas / Explotación de vulnerabilidades en librerías de automatización	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Actualización periódica de dependencias y escaneo de vulnerabilidades (SCA).
94	Seguridad de Aplicación	Scripts de automatización con credenciales embebidas en texto plano / Exposición de credenciales de otros sistemas	4	4	16 (Alto)	10 (Moderado)	Reducir/Mitigar	Uso de gestor de secretos (vault) para credenciales de pruebas.
95	Seguridad de Datos	Resultados de pruebas almacenan datos sensibles sin protección / Exposición de información al compartir reportes	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Enmascarar datos sensibles en los reportes generados.
96	Gestión de Identidad y Acceso	Cuenta de servicio con privilegios elevados para ejecutar pruebas / Abuso de la cuenta de servicio para acceso indebido	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Limitar privilegios de la cuenta de servicio al mínimo necesario.
97	Monitoreo y Respuesta	No se audita el uso de la herramienta de automatización / Ejecuciones no autorizadas sin detección	2	3	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Habilitar auditoría de ejecuciones y accesos.
98	Continuidad y Respaldo	Configuración de pruebas sin versionado ni respaldo / Pérdida de suites de prueba desarrolladas	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Versionar la configuración en el repositorio de código.
99	Seguridad Perimetral	Integración con sistemas externos (CI/CD) sin control de acceso / Uso de la herramienta como puente hacia otros sistemas	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Restringir y auditar las integraciones externas.
100	Concientización y Procesos	Equipo de QA sin capacitación en manejo seguro de credenciales de prueba / Malas prácticas que exponen accesos	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Capacitación en manejo seguro de credenciales y datos de prueba.

4.3 Activos del Ambiente de Desarrollo

Estación de trabajo del desarrollador (Hardware)

Responsable: Danny. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 11. Riesgos identificados — Estación de trabajo del desarrollador (Hardware)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
101	Seguridad Física	Laptops de desarrollo sin cable de seguridad ni resguardo / Robo de equipo con código fuente	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Uso de candados de seguridad y cifrado de disco.
102	Seguridad de Red	Conexión a redes Wi-Fi públicas sin VPN / Intercepción de credenciales y tráfico	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Uso obligatorio de VPN corporativa en redes externas.
103	Seguridad de Host	Estaciones sin antivirus/EDR centralizado / Infección por malware	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Desplegar EDR gestionado y políticas de actualización automática.
104	Seguridad de Aplicación	Instalación libre de software no autorizado / Ejecución de software malicioso o no licenciado	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Lista blanca de aplicaciones y permisos de instalación restringidos.
105	Seguridad de Datos	Código fuente y credenciales almacenados sin cifrado en el disco local / Exposición de información ante pérdida o robo del equipo	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Cifrado de disco completo (BitLocker/FileVault) obligatorio.
106	Gestión de Identidad y Acceso	Sesión de usuario con privilegios de administrador local permanentes / Escalamiento de privilegios por malware	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Principio de mínimo privilegio, cuenta estándar y elevación puntual.
107	Monitoreo y Respuesta	Sin registro centralizado de actividad en estaciones de desarrollo / Actividad maliciosa no detectada	2	3	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Centralizar logs de endpoint en el SIEM corporativo.
108	Continuidad y Respaldo	Trabajo local sin respaldo automático a repositorio / Pérdida de avances de desarrollo	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Políticas de commit frecuente y respaldo en la nube.
109	Seguridad Perimetral	Acceso directo a servicios internos sin pasar por VPN/proxy / Exposición de servicios internos desde estaciones comprometidas	2	4	8 (Moderado)	5 (Bajo)	Reducir/Mitigar	Forzar acceso a servicios internos mediante VPN y proxy corporativo.
110	Concientización y Procesos	Falta de capacitación en seguridad para desarrolladores / Prácticas inseguras de codificación (secretos en el código)	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Capacitación en secure coding y uso de gestores de secretos.

Repositorio de código (Git) (Software)

Responsable: Javier. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 12. Riesgos identificados — Repositorio de código (Git) (Software)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
111	Seguridad Física	Servidor Git autoalojado sin control de acceso físico / Acceso físico no autorizado al servidor	2	3	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Alojar el servidor en centro de datos con control de acceso.
112	Seguridad de Red	Acceso al repositorio sin restricción de origen / Acceso no autorizado desde redes externas	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Restringir el acceso por VPN o lista de IPs permitidas.
113	Seguridad de Host	Servidor Git con sistema operativo desactualizado / Explotación de vulnerabilidades del servidor	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Actualizaciones periódicas y hardening del servidor.
114	Seguridad de Aplicación	Sin revisión obligatoria de código antes de fusionar (merge) / Introducción de código malicioso o vulnerable	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Exigir revisión de código (pull request) y análisis estático antes de merge.
115	Seguridad de Datos	Historial del repositorio contiene credenciales expuestas en commits antiguos / Fuga de credenciales desde el historial de versiones	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Escaneo de secretos y limpieza del historial (git-secrets, purga de commits).
116	Gestión de Identidad y Acceso	Autenticación sin MFA para acceso al repositorio / Compromiso de cuentas de desarrolladores	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Habilitar autenticación multifactor para todos los usuarios.
117	Monitoreo y Respuesta	Sin auditoría de accesos y cambios en el repositorio / Modificaciones no autorizadas sin trazabilidad	2	4	8 (Moderado)	5 (Bajo)	Reducir/Mitigar	Habilitar logs de auditoría y alertas ante cambios sensibles.
118	Continuidad y Respaldo	Repositorio sin respaldo fuera del servidor principal / Pérdida del código fuente ante fallo o ataque	2	5	10 (Moderado)	6 (Moderado)	Reducir/Mitigar	Respaldo periódico en ubicación externa/nube.
119	Seguridad Perimetral	Webhooks del repositorio expuestos sin validación de firma / Manipulación de integraciones CI/CD mediante webhooks falsos	2	4	8 (Moderado)	5 (Bajo)	Reducir/Mitigar	Validar firmas de webhooks y restringir orígenes.
120	Concientización y Procesos	Falta de política de ramas y buenas prácticas de versionado / Errores humanos que generan brechas de seguridad	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Definir y capacitar en una política de branching y buenas prácticas Git.

Código fuente y credenciales (Datos)

Responsable: Katherin. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 13. Riesgos identificados — Código fuente y credenciales (Datos)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
121	Seguridad Física	Copias locales de código fuente en dispositivos sin cifrado / Exposición de código fuente ante robo de dispositivo	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Cifrado de disco obligatorio en todos los dispositivos de desarrollo.
122	Seguridad de Red	Transferencia de código y credenciales por canales no cifrados (FTP, email) / Intercepción de código fuente y credenciales	2	4	8 (Moderado)	5 (Bajo)	Reducir/Mitigar	Prohibir canales no cifrados y usar el repositorio Git como único medio de transferencia.
123	Seguridad de Host	Archivos de configuración con credenciales en texto plano en las estaciones / Robo de credenciales desde archivos locales	4	4	16 (Alto)	10 (Moderado)	Reducir/Mitigar	Eliminar credenciales en texto plano y usar variables de entorno seguras/gestor de secretos.
124	Seguridad de Aplicación	Credenciales de bases de datos y APIs embebidas directamente en el código / Exposición de credenciales al compartir o publicar el código	4	5	20 (Alto)	12 (Alto)	Reducir/Mitigar	Migrar a un gestor de secretos (Vault, AWS Secrets Manager) y eliminar credenciales embebidas.
125	Seguridad de Datos	Código fuente sin clasificación de confidencialidad / Divulgación de lógica de negocio y propiedad intelectual	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Clasificar el código fuente como información confidencial y restringir su distribución.
126	Gestión de Identidad y Acceso	Credenciales compartidas entre desarrolladores para acceso a ambientes / Falta de trazabilidad ante uso indebido	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Credenciales individuales y rotación periódica de secretos.
127	Monitoreo y Respuesta	Sin detección de credenciales expuestas en el código (secret scanning) / Credenciales filtradas sin ser detectadas a tiempo	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Implementar escaneo automático de secretos en cada commit/pipeline.
128	Continuidad y Respaldo	Credenciales críticas conocidas solo por una persona / Pérdida de acceso a sistemas ante ausencia del responsable	2	4	8 (Moderado)	5 (Bajo)	Reducir/Mitigar	Documentar y resguardar credenciales críticas en un gestor de secretos compartido y controlado.
129	Seguridad Perimetral	Credenciales de producción utilizadas en entornos de desarrollo / Compromiso de producción a través de un entorno de desarrollo vulnerado	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Prohibir el uso de credenciales de producción fuera de dicho ambiente.
130	Concientización y Procesos	Falta de capacitación sobre manejo seguro de secretos y credenciales / Prácticas inseguras que exponen código y credenciales	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Capacitación obligatoria en gestión segura de secretos para el equipo de desarrollo.

Desarrollador (Recursos Humanos)

Responsable: Josue. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 14. Riesgos identificados — Desarrollador (Recursos Humanos)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
131	Seguridad Física	Área de desarrollo sin control de acceso restringido / Acceso no autorizado a estaciones de desarrolladores	2	3	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Control de acceso a las áreas de desarrollo y políticas de escritorio limpio.
132	Seguridad de Red	Desarrolladores con acceso amplio a redes de producción para depuración / Uso de accesos de desarrollo para comprometer producción	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Restringir el acceso de desarrollo a producción mediante segmentación y aprobaciones.
133	Seguridad de Host	Estaciones de desarrollo con software y librerías de terceros sin control / Instalación de dependencias maliciosas	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Control de dependencias mediante repositorios internos verificados.
134	Seguridad de Aplicación	Prácticas de codificación sin seguir estándares de seguridad (OWASP) / Introducción de vulnerabilidades en el software desarrollado	4	4	16 (Alto)	10 (Moderado)	Reducir/Mitigar	Adoptar estándares seguros de codificación (OWASP) y revisiones de código.
135	Seguridad de Datos	Uso de datos de producción en el entorno local de desarrollo / Exposición de datos reales en equipos de desarrollo	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Prohibir el uso de datos reales de producción en desarrollo; usar datos sintéticos.
136	Gestión de Identidad y Acceso	Cuentas de desarrollador con acceso permanente a sistemas productivos / Acceso indebido a producción por parte de desarrolladores	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Acceso a producción solo temporal y aprobado (just-in-time access).
137	Monitoreo y Respuesta	Actividad de los desarrolladores en repositorios y sistemas no se audita / Cambios maliciosos o erróneos sin trazabilidad	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Auditoría de actividad en repositorios y sistemas de desarrollo.
138	Continuidad y Respaldo	Conocimiento crítico concentrado en pocos desarrolladores (bus factor) / Pérdida de continuidad ante salida de personal clave	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Documentación técnica y rotación de conocimiento entre el equipo.
139	Seguridad Perimetral	Desarrolladores con VPN de acceso amplio a toda la red corporativa / Uso de acceso VPN como vector de entrada a otros sistemas	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Segmentar el acceso VPN según el sistema que cada desarrollador requiere.
140	Concientización y Procesos	Falta de programa formal de concientización en seguridad para desarrolladores / Vulnerabilidades por desconocimiento de amenazas actuales	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Programa continuo de capacitación en seguridad y desarrollo seguro (SDLC seguro).

Entorno IDE / CI-CD (Software)

Responsable: Diancarlo. Criticidad del activo: 3 (Media). A continuación, los 10 riesgos evaluados para este activo, uno por cada capa del modelo de defensa en profundidad.

Tabla 15. Riesgos identificados — Entorno IDE / CI-CD (Software)

#	Capa	Brecha / Amenaza	P	I	MAGERI T	OCTAVE	Tratamien to	Solución
141	Seguridad Física	Servidor de CI/CD alojado sin control de acceso físico / Acceso físico no autorizado	2	3	6 (Moderado)	4 (Bajo)	Reducir/Mitigar	Ubicar el servidor de CI/CD en centro de datos controlado.
142	Seguridad de Red	Agentes de CI/CD con acceso amplio a la red interna / Uso del pipeline como pivote hacia otros sistemas	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Segmentar la red de los agentes de CI/CD con reglas restrictivas.
143	Seguridad de Host	Imágenes/agentes de CI/CD desactualizados / Explotación de vulnerabilidades en el entorno de ejecución	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Actualización periódica de imágenes base y agentes.
144	Seguridad de Aplicación	Pipeline ejecuta código de dependencias sin verificación / Ataques a la cadena de suministro (supply chain)	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Verificación de integridad de dependencias y uso de repositorios confiables.
145	Seguridad de Datos	Variables de entorno con secretos visibles en logs del pipeline / Exposición de credenciales en registros de ejecución	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Uso de gestor de secretos y enmascaramiento de variables sensibles en logs.
146	Gestión de Identidad y Acceso	Cuenta de servicio del pipeline con permisos de administrador / Abuso de privilegios excesivos del pipeline	3	5	15 (Alto)	9 (Moderado)	Reducir/Mitigar	Aplicar mínimo privilegio a las cuentas de servicio del CI/CD.
147	Monitoreo y Respuesta	Sin alertas ante fallos o cambios inusuales en el pipeline / Manipulación del proceso de build/despliegue sin detección	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Monitoreo y alertas sobre cambios en la configuración del pipeline.
148	Continuidad y Respaldo	Configuración del pipeline sin versionado (pipeline as code) / Pérdida de configuración crítica de despliegue	2	4	8 (Moderado)	5 (Bajo)	Reducir/Mitigar	Definir el pipeline como código versionado en el repositorio.
149	Seguridad Perimetral	Acceso al panel del CI/CD expuesto a internet sin restricción / Acceso externo no autorizado a la plataforma de CI/CD	3	4	12 (Alto)	7 (Moderado)	Reducir/Mitigar	Restringir el acceso mediante VPN y autenticación reforzada.
150	Concientización y Procesos	Falta de capacitación en seguridad de pipelines (DevSecOps) / Introducción de prácticas inseguras en el proceso de integración	3	3	9 (Moderado)	5 (Bajo)	Reducir/Mitigar	Capacitar al equipo en prácticas DevSecOps.

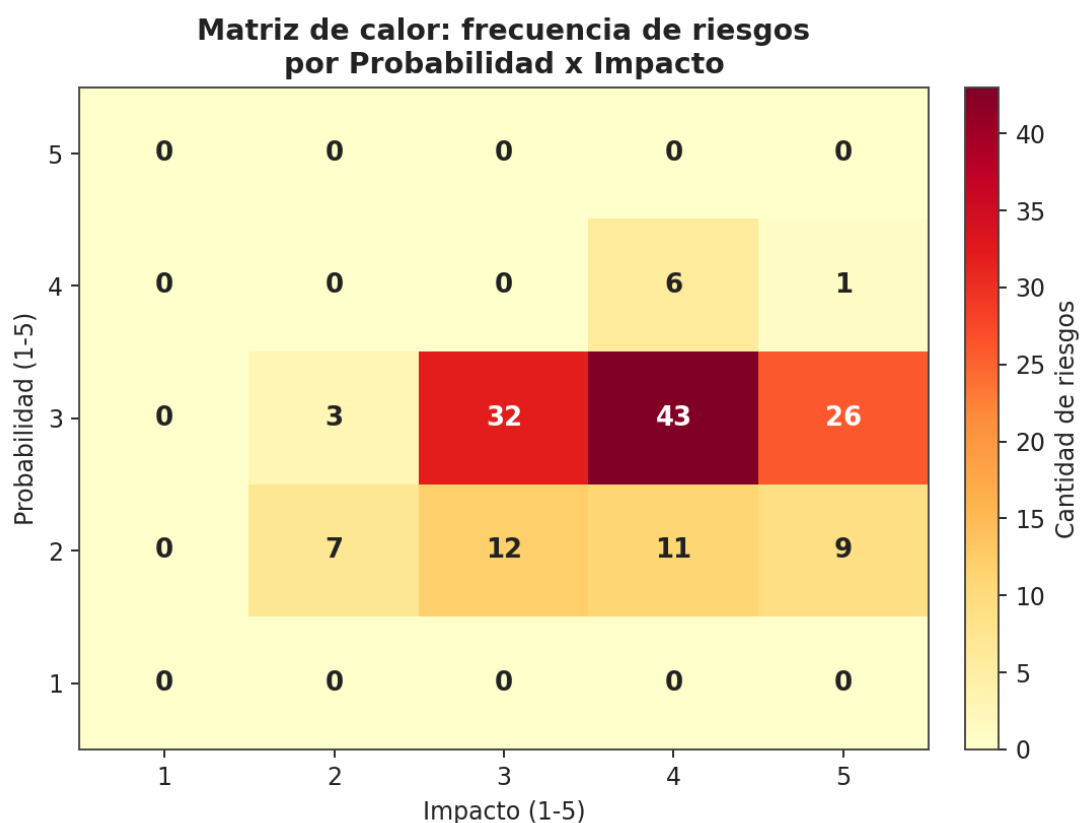
5. CONSOLIDACIÓN Y TRATAMIENTO DE RIESGOS

Con base en los 150 riesgos identificados sobre los 15 activos evaluados, esta sección consolida los resultados, visualiza su distribución mediante gráficas y establece una priorización de acciones de tratamiento.

5.1 Matriz de calor

La matriz de calor cruza la probabilidad de ocurrencia (1 a 5) con el impacto (1 a 5). La mayor concentración de riesgos se ubica en probabilidad media (3) combinada con impacto medio-alto (3 y 4), con 32 y 43 riesgos respectivamente en esas celdas; no se registraron riesgos en las combinaciones de probabilidad o impacto extremos (1 o 5 en ambos ejes simultáneamente).

Figura 3. Matriz de calor: frecuencia de riesgos por probabilidad x impacto.



5.2 Consolidación por nivel de criticidad

De los 150 riesgos analizados, la evaluación MAGERIT clasificó 76 como de nivel alto, 67 como moderados y 7 como bajos, sin registrar riesgos críticos. La evaluación OCTAVE Allegro, que pondera adicionalmente la criticidad del activo contenedor, clasificó 78 riesgos como moderados, 64 como bajos y 8 como altos. La diferencia entre ambas evaluaciones se explica porque OCTAVE Allegro atenúa el nivel de riesgo en activos de criticidad media o baja, aun cuando su puntaje MAGERIT sea alto.

Figura 4. Distribución de los 150 riesgos por nivel de criticidad (MAGERIT vs. OCTAVE Allegro).

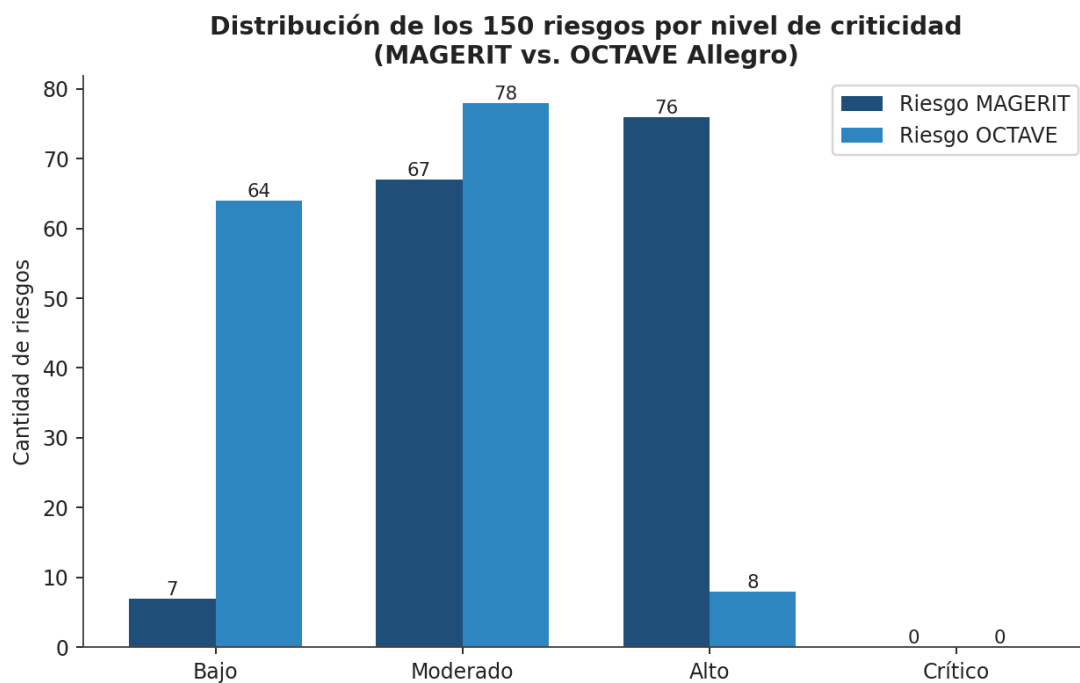
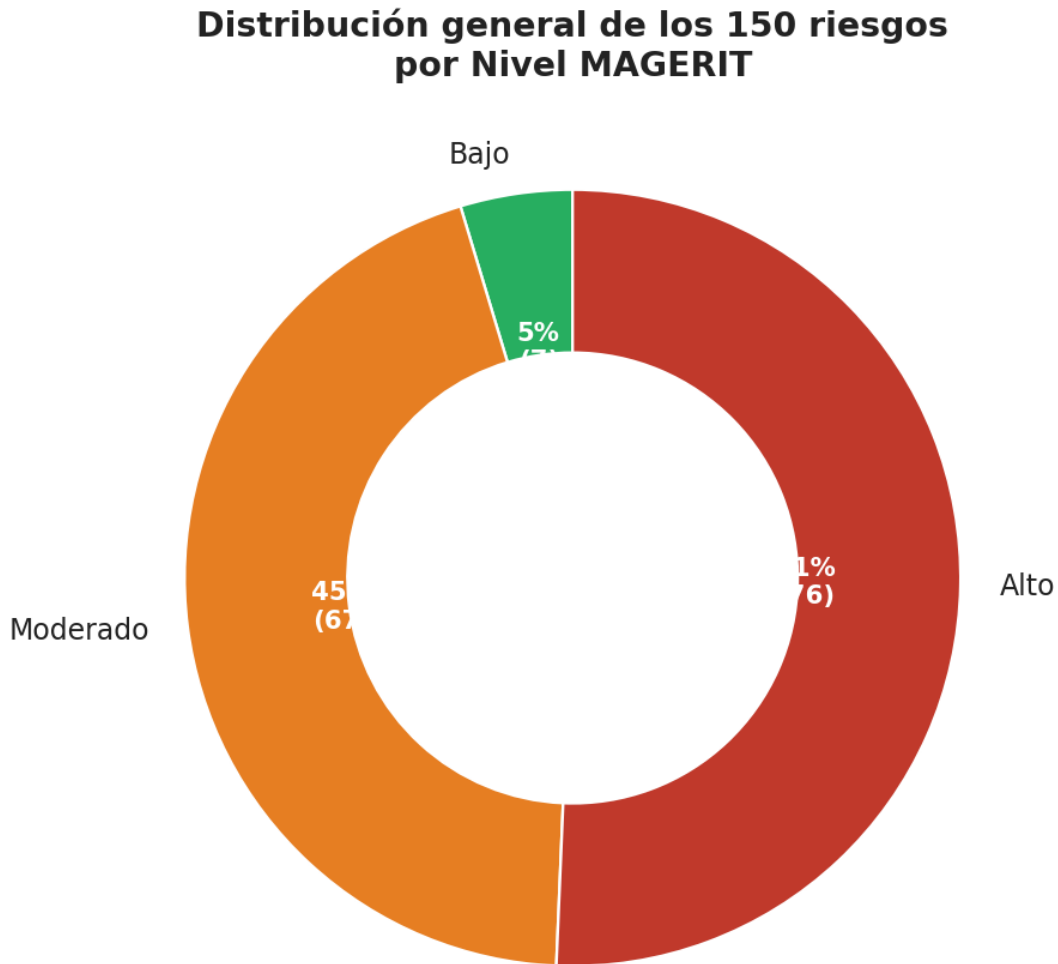


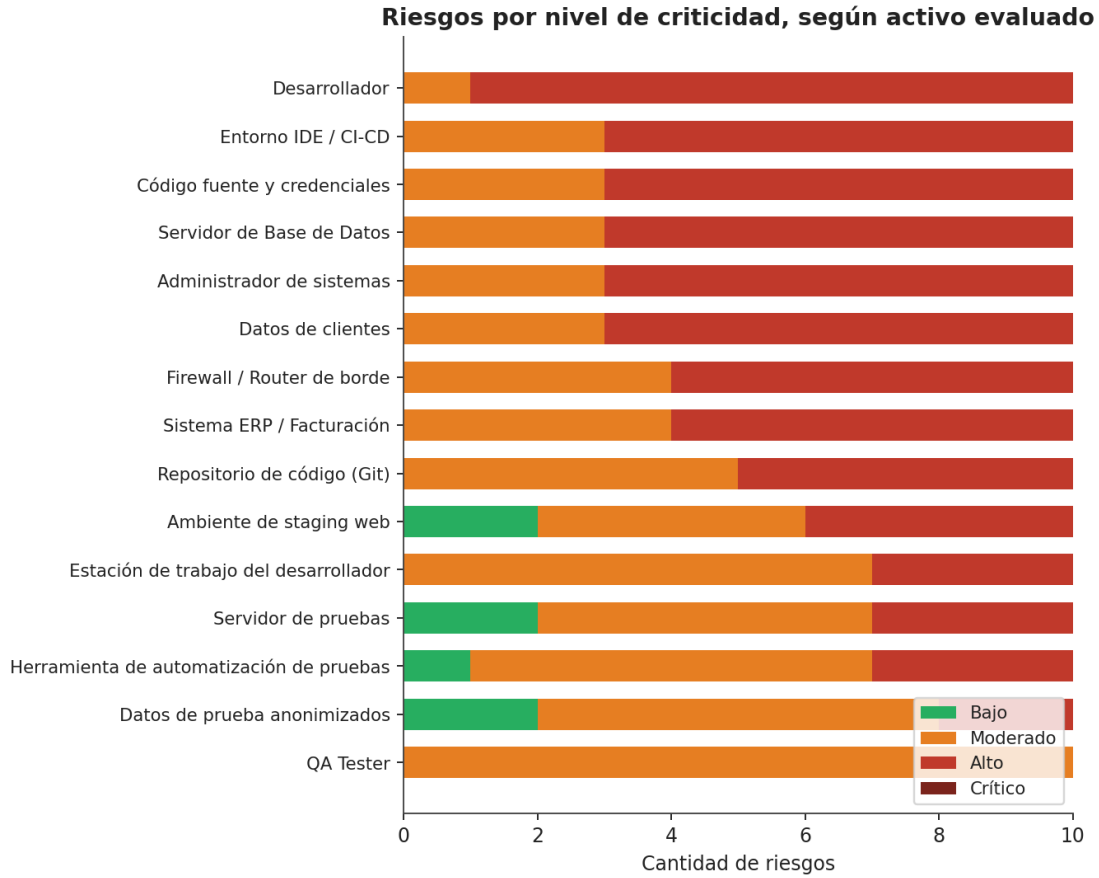
Figura 5. Distribución general de los 150 riesgos por nivel MAGERIT.



5.3 Riesgos por activo evaluado

El activo Desarrollador concentra la mayor proporción de riesgos de nivel alto (9 de 10), seguido de Entorno IDE/CI-CD, Código fuente y credenciales, Servidor de Base de Datos, Administrador de sistemas y Datos de clientes (6 de 10 cada uno). En el otro extremo, QA Tester y Datos de prueba anonimizados presentan la menor proporción de riesgos altos, concentrando la mayoría de sus riesgos en el nivel moderado o bajo.

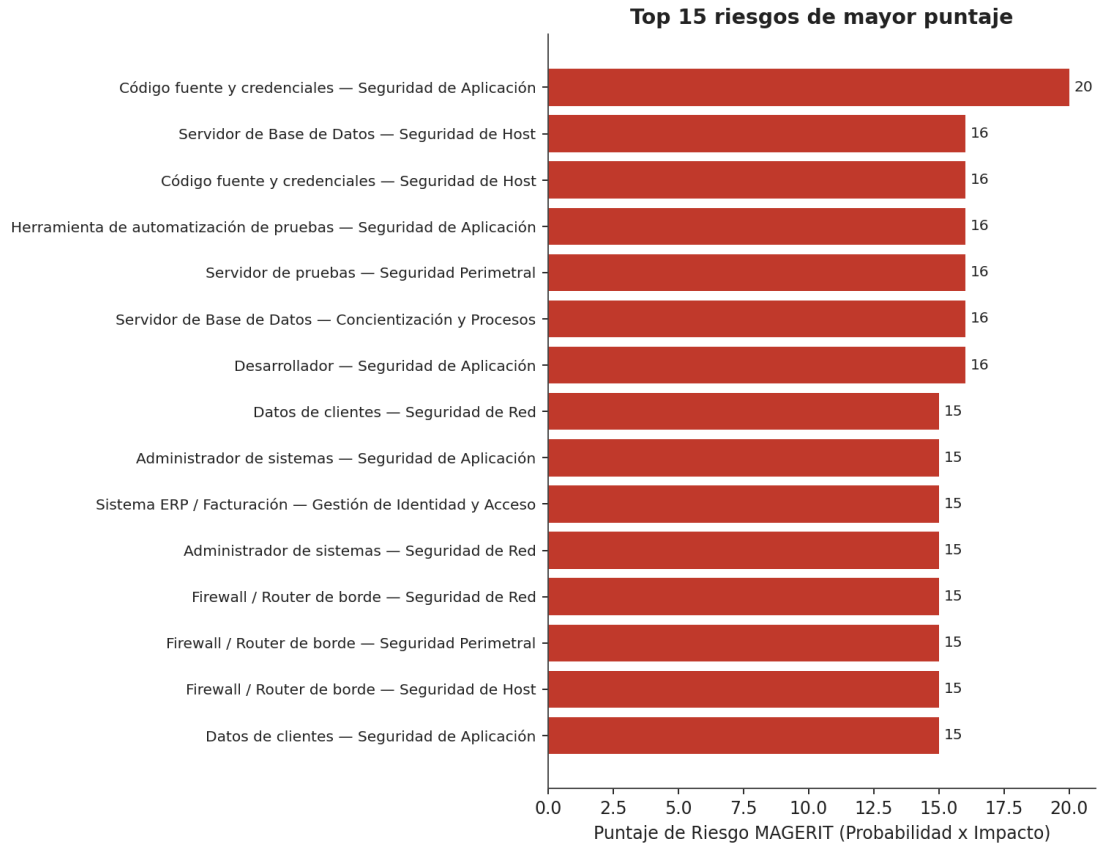
Figura 6. Riesgos por nivel de criticidad, según activo evaluado.



5.4 Priorización de acciones (Top 15)

Se priorizan los 15 riesgos de mayor puntaje MAGERIT, que concentran el mayor potencial de impacto sobre la confidencialidad, integridad y disponibilidad de los activos. El riesgo de mayor puntaje corresponde a la exposición de credenciales al compartir o publicar código fuente (puntaje 20), seguido de un grupo de seis riesgos con puntaje 16 relacionados con explotación de vulnerabilidades, gestión de parches y exposición de credenciales en distintos activos.

Figura 7. Top 15 riesgos de mayor puntaje MAGERIT.



6. PLAN DE IMPLEMENTACIÓN

El plan de implementación traduce los resultados del análisis de riesgos en una hoja de ruta escalonada de tres fases, según el puntaje y nivel de criticidad de los riesgos a tratar, complementada con un cronograma general y un presupuesto estimado referencial.

6.1 Fase 1: Acción inmediata (0-3 meses)

La Fase 1 concentra las acciones sobre los 15 riesgos de mayor puntaje MAGERIT (puntaje entre 15 y 20), cuya materialización tendría el impacto más severo sobre los activos evaluados. Estas acciones deben iniciarse de forma inmediata:

- **Código fuente y credenciales — Seguridad de Aplicación:** Exposición de credenciales al compartir o publicar el código. *Solución: Migrar a un gestor de secretos (Vault, AWS Secrets Manager) y eliminar credenciales embebidas.*
- **Servidor de Base de Datos — Seguridad de Host:** Explotación de vulnerabilidades conocidas. *Solución: Gestión de parches automatizada y hardening del sistema operativo del servidor.*
- **Servidor de Base de Datos — Concientización y Procesos:** Explotación de vulnerabilidades no corregidas. *Solución: Proceso formal de gestión de parches con SLA de aplicación.*
- **Servidor de pruebas — Seguridad Perimetral:** Ataques de fuerza bruta desde internet. *Solución: Cerrar el acceso directo a internet y usar VPN o bastion host.*
- **Herramienta de automatización de pruebas — Seguridad de Aplicación:** Exposición de credenciales de otros sistemas. *Solución: Uso de gestor de secretos (vault) para credenciales de pruebas.*
- **Código fuente y credenciales — Seguridad de Host:** Robo de credenciales desde archivos locales. *Solución: Eliminar credenciales en texto plano y usar variables de entorno seguras/gestor de secretos.*
- **Desarrollador — Seguridad de Aplicación:** Introducción de vulnerabilidades en el software desarrollado. *Solución: Adoptar estándares seguros de codificación (OWASP) y revisiones de código.*

- **Servidor de Base de Datos — Seguridad de Red:** Acceso remoto no autorizado. *Solución: Segmentar la red de administración (VLAN dedicada) y exigir VPN + MFA para acceso remoto.*
- **Servidor de Base de Datos — Seguridad de Aplicación:** Inyección SQL / escalamiento de privilegios. *Solución: Validación de entradas, consultas parametrizadas y bastionado del motor de base de datos.*
- **Servidor de Base de Datos — Seguridad de Datos:** Fuga de información confidencial. *Solución: Cifrar los datos en reposo (TDE) y en tránsito (TLS).*
- **Sistema ERP / Facturación — Seguridad de Aplicación:** Inyección de código / manipulación de transacciones. *Solución: Pruebas de seguridad de aplicaciones (SAST/DAST) antes de cada release.*
- **Sistema ERP / Facturación — Gestión de Identidad y Acceso:** Fraude interno o modificación indebida de facturas. *Solución: Revisión periódica de roles y segregación de funciones (SoD).*
- **Datos de clientes — Seguridad de Red:** Intercepción de información personal en tránsito. *Solución: Cifrado TLS obligatorio en todas las transferencias de datos.*
- **Datos de clientes — Seguridad de Host:** Compromiso del servidor que aloja los datos. *Solución: Hardening del servidor de base de datos y monitoreo de integridad.*
- **Datos de clientes — Seguridad de Aplicación:** Exfiltración de datos mediante consultas no controladas. *Solución: Implementar capa de API con control de acceso y limitación de consultas.*

6.2 Fase 2: Corto plazo (3-6 meses)

La Fase 2 aborda los 61 riesgos restantes de nivel alto (puntaje entre 12 y 15, sin incluir los ya tratados en la Fase 1), distribuidos principalmente en los activos Servidor de Base de Datos, Sistema ERP/Facturación, Datos de clientes, Administrador de sistemas, Firewall/Router de borde, Repositorio de código y Estación de trabajo del desarrollador. Las medidas priorizadas en esta fase incluyen cifrado de datos en tránsito y en reposo, autenticación multifactor, segmentación de red mediante VLAN dedicadas, gestión de accesos privilegiados (PAM) y revisión de reglas de firewall, en línea con las recomendaciones del OWASP Top 10 (OWASP Foundation, 2021).

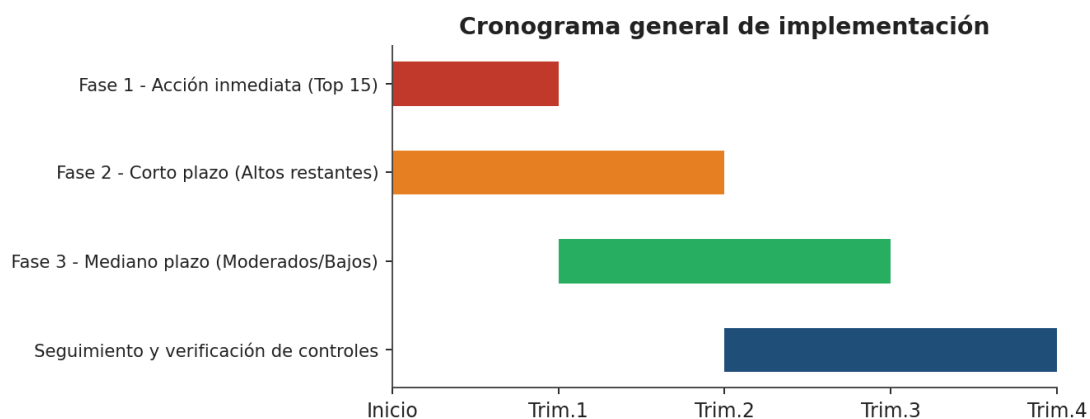
6.3 Fase 3: Mediano plazo (6-12 meses)

La Fase 3 atiende los 67 riesgos de nivel moderado y los 7 riesgos de nivel bajo, una vez tratados los riesgos altos de las fases anteriores. Las acciones en esta fase se orientan al endurecimiento (hardening) de equipos y aplicaciones, la formalización de procesos de gestión de cambios y parches, la implementación de monitoreo centralizado (SIEM) y la capacitación continua del personal en buenas prácticas de seguridad.

6.4 Cronograma general

El siguiente cronograma resume, en trimestres, la ejecución de las tres fases del plan de implementación.

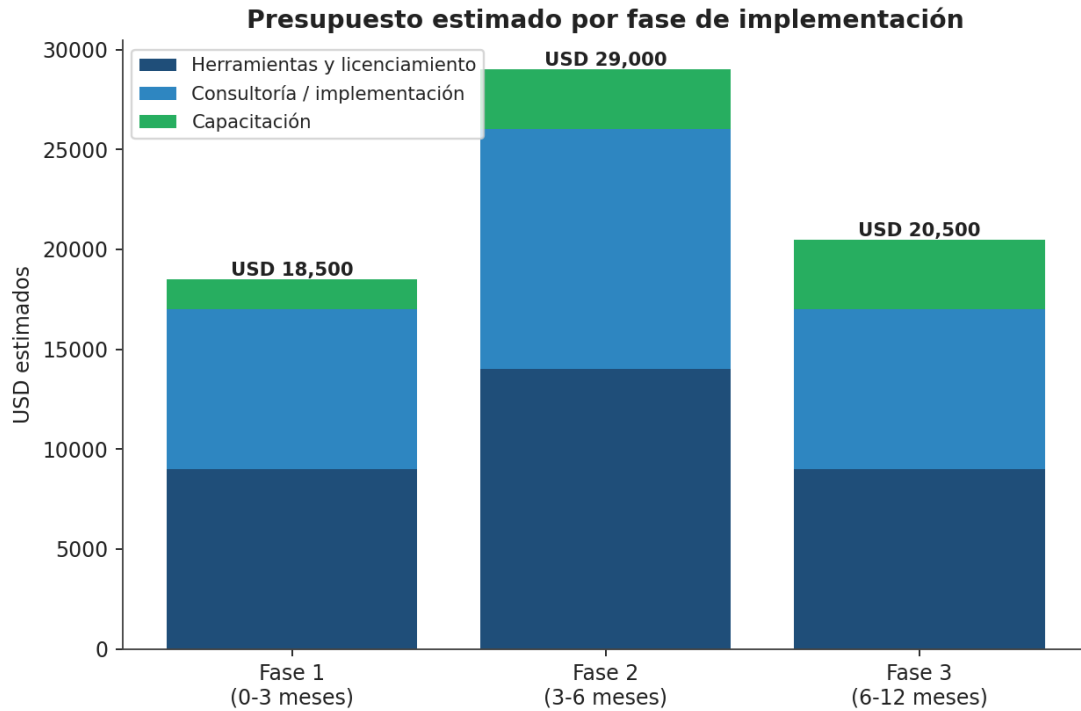
Figura 8. Cronograma general de implementación.



6.5 Presupuesto estimado y reducción del impacto financiero

El presupuesto que se presenta a continuación corresponde a una estimación referencial elaborada con fines académicos, expresada en dólares estadounidenses (USD), y contempla herramientas de seguridad, servicios de consultoría/implementación y capacitación del personal por cada fase.

Figura 9. Presupuesto estimado por fase de implementación.

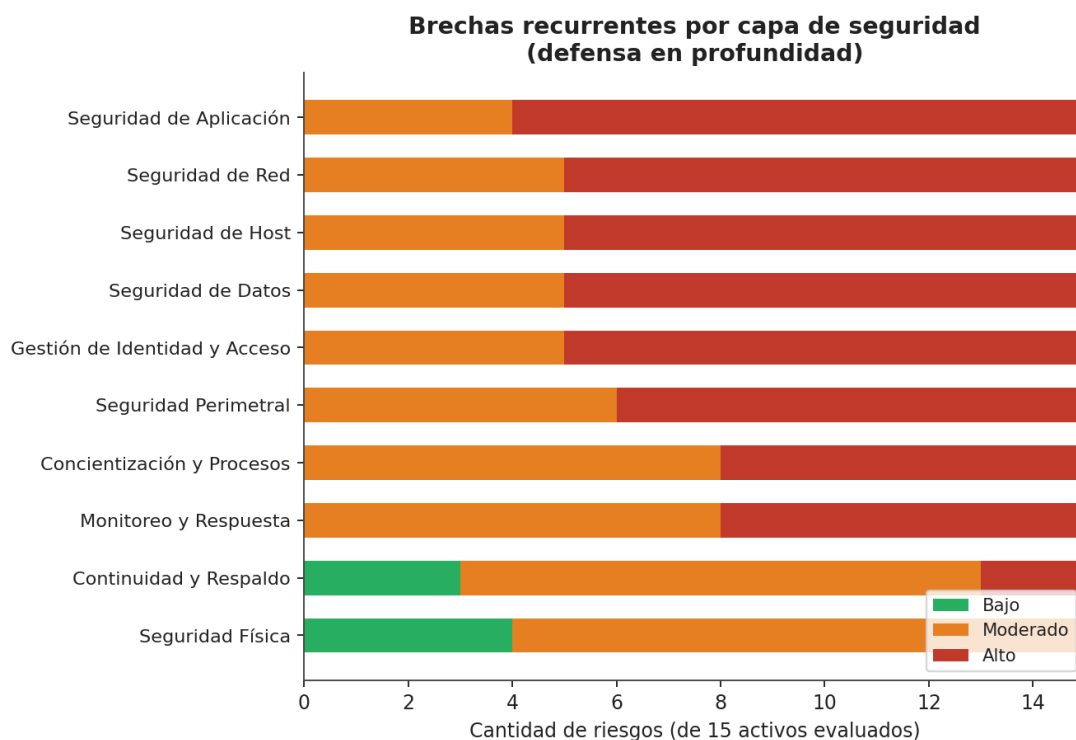


La inversión total estimada asciende a USD 68,000 antes de contingencia; considerando una contingencia del 10% ($\approx$ USD 6,800), el total general estimado es de $\approx$ USD 74,800. Esta inversión escalonada prioriza primero los 15 riesgos de mayor puntaje —varios de ellos sobre activos con impacto financiero directo, como el Sistema ERP/Facturación y el Servidor de Base de Datos—, buscando reducir cuanto antes la probabilidad y el costo potencial de incidentes de alto impacto (fraude interno, fuga de datos de clientes, explotación de vulnerabilidades conocidas), antes de abordar los riesgos de menor puntaje en las fases 2 y 3.

7. ANÁLISIS DE BRECHAS

A partir de la revisión transversal de las brechas identificadas en los 150 riesgos analizados, se observan patrones recurrentes que afectan de forma distinta a cada capa del modelo de defensa en profundidad, dado que cada capa fue evaluada de manera uniforme en los 15 activos.

Figura 10. Brechas recurrentes por capa de seguridad (defensa en profundidad).



La capa de Seguridad de Aplicación concentra la mayor proporción de riesgos de nivel alto (11 de 15 activos), seguida por Gestión de Identidad y Acceso, Seguridad de Red, Seguridad de Host y Seguridad de Datos (10 de 15 cada una), y Seguridad Perimetral (9 de 15). En el otro extremo, Seguridad Física y Continuidad y Respaldo presentan la menor proporción de riesgos altos (0 y 2 de 15, respectivamente), lo que indica una postura relativamente más sólida en controles físicos y de respaldo frente a los controles de aplicación, identidad y red. Estos hallazgos sugieren que la organización debe priorizar el fortalecimiento de las prácticas de codificación segura, la gestión de identidades y accesos, y la segmentación de red como líneas transversales de mejora.

8. ASPECTOS NORMATIVOS Y LEGALES

El tratamiento de los riesgos identificados debe enmarcarse en el contexto normativo aplicable a la organización, tanto en el ámbito nacional guatemalteco como en los estándares y marcos internacionales de referencia utilizados en este trabajo.

8.1 Marco normativo nacional (Guatemala)

En Guatemala, el tratamiento de la información y los delitos informáticos se relacionan principalmente con la Ley de Acceso a la Información Pública (Decreto 57-2008), que establece obligaciones de protección sobre datos personales en poder de sujetos obligados, y con las reformas al Código Penal (Decreto 33-96 y modificaciones posteriores) que tipifican delitos como el acceso ilícito a sistemas informáticos, la destrucción de registros informáticos y el uso de información sin autorización. A la fecha de este análisis, Guatemala no cuenta con una ley general de protección de datos personales para el sector privado, por lo que la organización debe adoptar como práctica de buen gobierno los principios generales de minimización, finalidad y seguridad de los datos, anticipándose a una eventual regulación específica.

8.2 Marcos y estándares internacionales de referencia

El análisis se apoya en referentes internacionales como MAGERIT (Gobierno de España), OCTAVE Allegro (Software Engineering Institute, Carnegie Mellon), el modelo de defensa en profundidad y el catálogo OWASP Top 10, complementados por el estándar ISO/IEC 27005 para la gestión de riesgos de seguridad de la información. Adicionalmente, dado que el activo Sistema ERP/Facturación procesa datos financieros y de clientes, resulta pertinente evaluar la aplicabilidad de controles alineados con PCI DSS en caso de procesarse datos de tarjetas de pago, así como considerar el Reglamento General de Protección de Datos (RGPD/GDPR) de la Unión Europea si la organización llegara a tratar datos de clientes o usuarios residentes en dicho bloque.

8.3 Implicaciones para el tratamiento de riesgos

El cumplimiento normativo refuerza, en particular, el tratamiento de los riesgos asociados con los activos de Datos de Clientes y Código Fuente y Credenciales, donde una fuga de información podría derivar en responsabilidades legales adicionales a las pérdidas operativas. Se recomienda documentar formalmente las bases legales de tratamiento de datos, los acuerdos de confidencialidad con el personal y terceros, y un procedimiento de notificación de incidentes que sea consistente con las mejores prácticas internacionales, aun en ausencia de una obligación legal local específica.

9. PLAN DE CONTINUIDAD DE NEGOCIO

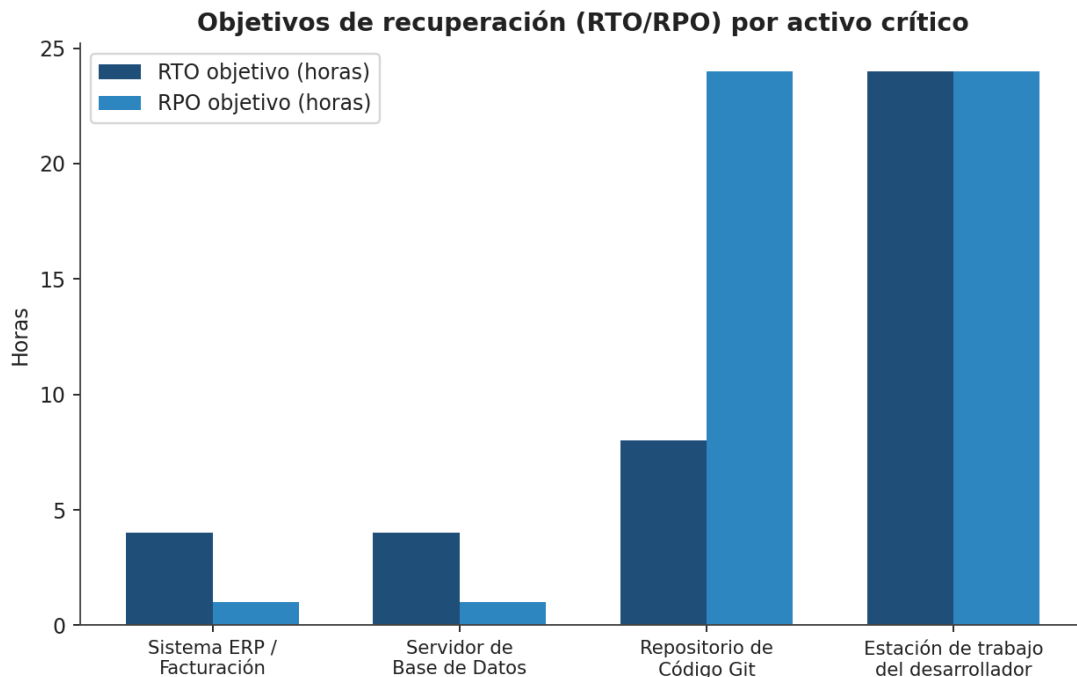
El Plan de Continuidad de Negocio (BCP, por sus siglas en inglés) complementa el tratamiento de riesgos al establecer la capacidad de la organización para mantener o restablecer sus operaciones críticas ante la materialización de un incidente severo, en particular los riesgos de mayor puntaje identificados sobre el Sistema ERP y el Servidor de Base de Datos.

9.1 Objetivo y alcance

El plan tiene como objetivo garantizar la continuidad de los procesos de facturación, gestión de clientes y desarrollo de software ante escenarios de indisponibilidad de los ambientes de producción, pruebas o desarrollo, priorizando la restauración del Sistema ERP/Facturación y del Servidor de Base de Datos, identificados como los activos más críticos en el análisis de riesgos.

9.2 Análisis de impacto al negocio (BIA) y objetivos de recuperación

Figura 11. Objetivos de recuperación (RTO/RPO) por activo crítico.



- **Sistema ERP/Facturación** — RTO 4 horas, RPO 1 hora. Impacto: interrupción de la facturación y atención a clientes; impacto financiero directo.
- **Servidor de Base de Datos** — RTO 4 horas, RPO 1 hora. Impacto: pérdida de acceso a datos de clientes y transacciones; afecta a todos los sistemas dependientes.
- **Repositorio de Código Git** — RTO 8 horas, RPO 24 horas. Impacto: detiene la entrega de software; impacto operativo sobre el equipo de desarrollo.
- **Estación de trabajo del desarrollador** — RTO 24 horas, RPO 24 horas. Impacto: retraso puntual en tareas de desarrollo; impacto acotado a un individuo o equipo.

9.3 Estrategias de continuidad

- Respaldos automatizados e inmutables del Sistema ERP y la base de datos de producción, con pruebas periódicas de restauración.
- Sitio o instancia de recuperación (on-premise o en la nube) capaz de restablecer los servicios críticos dentro del RTO definido.
- Replicación del repositorio de código en un proveedor externo (Git remoto) como respaldo adicional al alojamiento principal.
- Procedimientos documentados de failover y reversión (rollback) para el ambiente de producción.

9.4 Roles, responsabilidades y comunicación

Se conforma un equipo de gestión de crisis integrado por el administrador de sistemas, un representante de desarrollo y un responsable de comunicación con clientes, encargado de activar el plan, coordinar la restauración de servicios y comunicar el estado del incidente a las partes interesadas internas y externas conforme a un protocolo de comunicación previamente definido.

9.5 Pruebas y mantenimiento del plan

El plan debe someterse a pruebas semestrales mediante ejercicios de simulación (tabletop) y, al menos una vez al año, mediante una prueba de restauración real en un ambiente aislado. Los resultados de cada prueba deben documentarse y utilizarse para actualizar el plan y ajustar los objetivos de recuperación según la evolución de los activos y riesgos de la organización.

10. CONCLUSIONES

El desarrollo del análisis permitió evidenciar que la gestión de riesgos de seguridad de la información debe abordarse de manera integral, considerando no solamente los componentes tecnológicos, sino también los procesos, las personas y las condiciones físicas que intervienen en la operación de los sistemas. La aplicación uniforme de las diez capas del modelo de defensa en profundidad sobre los 15 activos evaluados permitió generar un panorama comparable y exhaustivo de 150 riesgos, valorados a partir de MAGERIT y complementados con la perspectiva de criticidad de activo de OCTAVE Allegro.

Los resultados muestran que, si bien ningún riesgo alcanzó el nivel crítico, 76 de los 150 riesgos (más de la mitad) se clasificaron como de nivel alto, concentrados principalmente en las capas de seguridad de aplicación, gestión de identidad y acceso, seguridad de red, seguridad de host y seguridad de datos. Los escenarios de mayor puntaje incluyen la exposición de credenciales en el código fuente, la explotación de vulnerabilidades conocidas, los ataques de fuerza bruta y el fraude interno por configuración deficiente de roles, todos ellos con potencial de afectar directamente la confidencialidad, integridad y disponibilidad de los activos, así como generar consecuencias financieras y operativas para la organización.

Ante estas condiciones, las medidas propuestas se orientan principalmente a la mitigación mediante controles de seguridad aplicados en diferentes capas, priorizando primero los 15 riesgos de mayor puntaje y escalonando después el tratamiento del resto de riesgos altos, moderados y bajos a lo largo de un plan de doce meses con presupuesto estimado de USD 74,800. Estas acciones se encuentran alineadas con el principio de defensa en profundidad, mediante el cual diferentes controles actúan de forma complementaria para evitar que la vulneración de una capa comprometa directamente al activo protegido.

El análisis realizado demuestra que la seguridad no debe considerarse como un conjunto aislado de herramientas tecnológicas, sino como un proceso continuo de identificación, evaluación, tratamiento y seguimiento de los riesgos. La priorización de los escenarios de mayor puntaje y la implementación progresiva de controles permiten fortalecer la postura de seguridad de la organización y reducir su exposición y su exposición financiera ante amenazas internas y externas.

11. REFERENCIAS

- Caralli, R. A., Stevens, J. F., Young, L. R., y Wilson, W. R. (2007). *Introducing OCTAVE Allegro: Improving the information security risk assessment process*. Software Engineering Institute, Carnegie Mellon University.
- Forum of Incident Response and Security Teams. (2019). *Common Vulnerability Scoring System version 3.1: Specification document*. FIRST. <https://www.first.org/cvss/>
- International Organization for Standardization. (2018). *ISO/IEC 27005: Information technology — Security techniques — Information security risk management*. ISO.
- Ministerio de Hacienda y Administraciones Públicas. (2012a). *MAGERIT — versión 3.0. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro I: Método*. Gobierno de España.
- Ministerio de Hacienda y Administraciones Públicas. (2012b). *MAGERIT — versión 3.0. Metodología de Análisis y Gestión de Riesgos de los Sistemas de Información. Libro II: Catálogo de Elementos*. Gobierno de España.
- OWASP Foundation. (2021). *OWASP Top 10: The ten most critical web application security risks*. <https://owasp.org/Top10/>

12. ANEXOS

El detalle completo y trazable de los 150 riesgos evaluados incluyendo brecha, amenaza, probabilidad, impacto, puntaje y nivel MAGERIT, puntaje y nivel OCTAVE, tratamiento y solución propuesta para cada uno— se presenta de forma narrativa en la sección 4 de este documento, organizado por ambiente y activo. El registro digital original, con fórmulas de cálculo automático y las hojas de Inventario de Activos, Matriz de Calor y Tratamiento, se encuentra disponible en el archivo de trabajo PLANTILLA_EVAL_SEG_MAGERIT_OCTAVE.xlsx, utilizado como fuente de datos para las gráficas de este informe.